Freigabeprotokoll „Vertrag = Maschine“

Lymbe AI · Kunden-AVV 1.7 und Datenschutzerklärung 1.6

Abnahme	Christian Gudermann, 26lab.io
Freigabe	Dennis Link, Flubber Pixels UG
Stand	11. Oktober 2026

Zweck: Jede technische Zusage, die im Kunden-AVV v1.7, in § 12 des Kunden-AVV und in der Datenschutzerklärung v1.6 steht, wird hier einzeln bestätigt – mit Datum, Fundstelle im System und Unterschrift. Der AVV v1.7 wird freigeschaltet, wenn alle Zeilen in Block A und B entweder mit ✅ bestätigt oder mit ⏳ und Datum eingetragen sind; ⏳ ist nur zulässig für Zusagen, die vor dem Datum gegenüber keinem Kunden greifen (Fristen laut 00_Steuerung/02_Finale_To_Dos.md). Was nicht bestätigt werden kann, wird im Vertrag geändert, nicht umgekehrt.

Ausfüllen: Spalte „Stand" = ✅ läuft / ❌ läuft nicht / ⏳ bis [Datum] · Spalte „Beleg" = Datei, Konfigurationszeile, Screenshot oder Messung.

> **Prüflauf 06.10.2026 (Claude Code für Christian Gudermann):** Code im Repo `lymbe-ai` (Stand Commit 89e4b3d) und Messungen am laufenden System lymbe-prod. Jede Messung an Datenbank und Containern lief über `scripts/zugriff.sh` und steht im Protokoll `BetriebsZugriff`. ✅ = am System nachgemessen bzw. im Code belegt. ❌ = Zusage stimmt heute nicht – Vertrag oder System muss angepasst werden. Offen = kann nur Chris/Dennis bestätigen (Konten, Verträge, Unterschriften). Original vor dem Prüflauf: `5.9_…vor-pruefung-2026-10-06.md`.

A – Zusagen aus dem Kunden-AVV v1.7 (Pflicht vor Freischaltung)

Nr	Zusage	Fundstelle Vertrag	Stand	Beleg	Datum
A1	Werkstatt für Abläufe läuft über Microsoft Azure OpenAI (EU-Datenzone), nicht über OpenAI direkt	Anlage 2 Nr. 4	✅	`AI_PROVIDER_WERKSTATT=azure` und `AI_PROVIDER=stackit` im laufenden App-Container (printenv, protokolliert)	06.10.2026
A2	Datenbank-Sicherungen werden nach 7 Tagen überschrieben	§ 8 Abs. 1, Anlage 1	✅	`scripts/backup-datenbanken.sh`, Cron 03:30; auf dem Server liegen die Tagesordner 30.09.–06.10. (plus eine Handsicherung 05.10.); Storage Box: tägliche Schnappschüsse, 7 behalten	06.10.2026
A2b	Hetzner-Server-Abbilder (inkl. Mailvolume, DKIM-Schlüssel) werden nach 7 Tagen überschrieben	§ 8 Abs. 1	✅	Hetzner-API: Backups aktiv (Fenster 22–02 UTC), genau 7 Abbilder 29.09.–05.10.2026	06.10.2026
A3	Gespräche (Kundenservice, Live-Chat, Digitaler Mitarbeiter, Frag Lymbe) werden automatisch 90 Tage nach der letzten Nachricht gelöscht – Löschlauf existiert und läuft	§ 8 Abs. 1	✅	Inngest-Funktion `cleanup-old-conversations`, täglich 02:00 UTC (`inngest/functions/data/cleanup-conversations.ts`, Regel `updatedAt < 90 Tage`). Messung in demo, lea, flubber, flubber-pixels: 0 Gespräche und 0 Portal-Chats älter als 91 Tage; ältestes Gespräch 54 Tage – an einem echten Altfall hat der Lauf also noch nicht gegriffen. **Nachtrag 08.10.2026:** Die Läufe 05.–08.10. endeten in Inngest als FAILED – gelöscht war alles, nur die Protokollzeile scheiterte (Fremdschlüssel, `actorId 'system'`). Behoben (Commit 40421ff): je Lauf eine Zeile in der Tabelle `LoeschLauf` (Zeit, fehlerfrei, Zahlen je Workspace) und `DATA_CLEANUP` im Audit-Log; die Betriebsprüfung meldet einen Lauf, der ausbleibt oder Fehler hat. Erster protokollierter Lauf 08.10.2026 06:39 UTC, fehlerfrei, 2 Workspaces	08.10.2026
A4	Schrittprotokolle im Ablauf-Kern werden spätestens nach 30 Tagen, ausgeführte Abläufe im Portal nach 90 Tagen gelöscht	§ 8 Abs. 1	✅	Schrittprotokolle und Dateien der Läufe: 30 Tage (`AP_EXECUTION_DATA_RETENTION_DAYS=30` im Kern). Lauf-Einträge (Eingaben/Ergebnis): mit der Gesprächsfrist, 90 Tage (Löschlauf `cleanup-old-conversations`, A3)	06.10.2026
A5	Ereignisdaten der Messenger-Anbindung (Inngest) werden nach 30 Tagen gelöscht (Vertragswert) – sonst tatsächliche Frist nennen	§ 8 Abs. 1	✅	`scripts/aufbewahrung-server.sh` löscht Inngest-Ereignisse und -Läufe älter als 30 Tage; am 06.10. von Hand gelaufen (0 Fehler), Cron täglich 04:45 ab 07.10.	06.10.2026
A6a	Zugriffs-/Betriebsprotokolle (Caddy, Mail-Logs) werden nach 14 Tagen gelöscht	§ 8 Abs. 1, 4.1 Abschn. 11	✅	Caddy und Mailserver schreiben keine eigenen Logdateien, nur in die Container-Logs (Caddyfile ohne `log`, Postfix/rspamd auf stdout). `scripts/aufbewahrung-server.sh` kürzt alle Container-Logs auf 14 Tage; Cron täglich 04:45 ab 07.10.	06.10.2026

Nr	Zusage	Fundstelle Vertrag	Stand	Beleg	Datum
A6b	Fehlerprotokoll wird nach 30 Tagen gelöscht	§ 8 Abs. 1, 4.1 Abschn. 11	✅	`lib/data-retention/policy.ts` `platformLogDays: 30`, nächtlicher Löschlauf (Fehlerprotokoll und Mail-Versandprotokoll). **Nachtrag 08.10.2026 (A31, Commit 3d97dfd):** keine Inhalte im Protokoll – Fehlerprotokoll und jede Logzeile der App (Docker-Log, Live-Log) werden vor dem Schreiben geschwärzt: Datenbankfehler ohne Aufruf-Argumente, KI-Fehler ohne Prompt/Verlauf, E-Mail-Adressen, Telefonnummern und lange Zitate ersetzt; Wissenssuche und Werkstätten loggen Längen statt Wortlaut. Vorher gemessen: 26 Zeilen, keine Gesprächsinhalte. Live-Test über das Demo-Widget mit erfundener Adresse/Telefonnummer: nichts davon im Log	06.10.2026, ergänzt 08.10.2026
A7	Selbstlernen ist im Auslieferungszustand aus; Einschalten wird mit Zeitpunkt und Nutzer protokolliert	§ 2 Abs. 1, § 3 Abs. 1	✅	Vorgabe `selfLearningMode @default(DISABLED)` (Mandanten-Schema). Jedes Speichern eines Assistenten schreibt `BOT_UPDATED` ins Audit-Log mit Person, Rolle, Zeit und allen Werten inkl. `selfLearningMode` (`server/actions/bot-actions.ts`). Schwäche: kein Vorher/Nachher, das Einschalten ist nur durch Vergleich zweier Einträge sichtbar	06.10.2026
A8	Portal-Einstellungen (Websuche, Selbstlernen, Benachrichtigungsziel, Dienst verbinden) werden mit Zeitpunkt und Nutzer protokolliert	§ 3 Abs. 1	❌	Protokolliert: Websuche abbestellen (Admin, Audit-Log), Selbstlernen (siehe A7). **Nicht protokolliert:** Benachrichtigungsziele (`integration-actions.ts`) und das Verbinden von Diensten (Shops, Kalender, WhatsApp, Meta, Postfächer, Verbindungen in den Abläufen). → Protokoll nachbauen oder § 3 Abs. 1 einschränken	
A9	Support-Zugriff auf Mandanteninhalte wird protokolliert (Zeitpunkt, Person, Grund, Umfang, Mandant) und setzt Freigabe voraus	§ 3 Abs. 5, Anlage 1	✅ (Protokoll) · Freigabe organisatorisch	Seit 06.10.2026: Zutritt ins Portal nur mit Support-Zugang (Grund, Umfang, Frist, jede Seite protokolliert); jede Einsicht im Admin-Bereich, Live-Log, psql/docker exec/docker logs protokolliert (Tabellen `SupportZugang`, `SupportAufruf`, `BetriebsZugriff`); der Kunde sieht alles unter Einstellungen → Datenschutz. Die Freigabe durch die zweite Person (Vier-Augen) ist **nicht technisch erzwungen** – sie läuft über Register 5.15 (siehe B5)	06.10.2026
A10	Websuche je Workspace auf Weisung abbestellbar (Konfiguration je Mandant, innerhalb von zwei Werktagen umsetzbar); Suchbegriff-Generator mit Filter und Blockiermeldung live; Testprotokoll 5.16 mit 30/30 vor Freischaltung	§ 3 Abs. 10	✅	Abbestellen im Admin je Workspace (`Tenant.websucheAbbestelltAm`, wirkt sofort); Generator `lib/ai/suchbegriff/*` mit Filter, Sperrliste und Blockiermeldung live; 5.16 Lauf 06.10.2026 30/30	06.10.2026
A11	Mistral-Rückfallebene ist deaktiviert (kein automatischer Rückfall auf nicht gelisteten Anbieter)	Anlage 2 (nicht gelistet)	✅	Im Code gibt es nur `openai`, `azure`, `stackit` (`lib/ai/providers.ts`), keinen automatischen Wechsel bei Fehlern; im App-Container keine MISTRAL-/FALLBACK-Variable. (KI-Bausteine im Abläufe-Kern nicht mitgeprüft)	06.10.2026

Nr	Zusage	Fundstelle Vertrag	Stand	Beleg	Datum
A12	Azure AI Speech: live ja/nein? Wenn ja: Aufnahmen werden nicht gespeichert (nur Transkript)	Anlage 2 Nr. 4, § 8 Abs. 1	✅ live	`AZURE_SPEECH_RESOURCE` gesetzt; schnelle Transkription in Germany West Central, die Aufnahme wird weder bei Lymbe noch bei Microsoft gespeichert (`lib/sprache/transkription.ts`), nur der abgeschickte Text	06.10.2026
A13	Messenger/Instagram über die Meta-App sind deaktiviert oder gleich behandelt wie WhatsApp	§ 5 Abs. 5	✅	Gleich behandelt: Erstnachricht aus 1.5 J für WhatsApp, Messenger und Instagram (Commit 466bab8); Messenger/Instagram laufen nur, wenn der Kunde sie selbst verbindet	06.10.2026
A14	Admin-Zugänge mit Mehr-Faktor-Anmeldung (Hetzner, GitHub, STACKIT, Azure, OpenAI, Stripe; SSH nur mit Schlüssel; Portal-Admins über 2FA-gesicherten Login)	Anlage 1	Teilweise	✅ SSH nur mit Schlüssel, kein Root per SSH (seit 06.10.2026, nachgemessen: Passwort und Root abgelehnt). ⚠ Portal: Admin-Bereich verlangt 2FA (Weiterleitung in `app/admin/layout.tsx`), die Anmeldung selbst erzwingt sie für Personal aber nicht. **Offen (Chris):** 2FA an den Konten Hetzner, GitHub, STACKIT, Azure, OpenAI, Stripe bestätigen	
A14b	Datensicherungen verschlüsselt und außerhalb des Servers abgelegt (Storage Box/Object Storage, nur anfügbar); Anlage 1 verspricht keine Datenträgerverschlüsselung mehr (Text seit AVV 1.7: Sicherungen, Passwörter und Zugangsdaten verschlüsselt, Rechenzentrum ISO 27001)	Anlage 1	✅ (Sicherungen 08.10.2026; Anlage 1 angepasst 11.10.2026)	**Nachtrag 08.10.2026 (A37):** Kopie außer Haus läuft seit 07.10. jede Nacht („ok gespiegelt“, zuletzt 08.10. 03:30, 8 Sicherungen). **Korrektur zum Prüflauf 06.10.:** Anlage 1 von AVV 1.6 nennt sehr wohl „verschlüsselte Datenträger (AES-256)“ – das stimmt nicht. Gemessen: eine ext4-Partition ohne LUKS, kein verschlüsselter Datenträger; Datenbanken, Dateiablage, Suchindex und Cache liegen unverschlüsselt auf der Hetzner-Platte. Verschlüsselt sind: Übertragung (TLS), alle Sicherungen (AES-256), Anmeldepasswörter (gehasht), Zugangsdaten verbundener Dienste in der App (AES-256-GCM: Datenbank-Passwörter, Shop-/Kalender-/Meta-/WhatsApp-Tokens, API-Quellen; Abläufe-Verbindungen im Kern). **Entscheidung Christian 08.10.2026:** keine Datenträgerverschlüsselung nachrüsten – Schutz der Platte übernimmt Hetzner (ISO/IEC 27001, Zutritt, Datenträgervernichtung); gegen Angriffe auf den laufenden Server hülfe sie nicht. Stattdessen passt Cowork die Texte an (siehe A37 in Notion): AVV Anlage 1, 1.7 R1, 4.1 Abschn. TOMs. Bisheriger Text: Eigene Sicherungen AES-256 (GPG) ✅. Kopie außer Haus: Storage Box Falkenstein eingerichtet, Ziel steht seit 06.10. 10:00 in der `.env` – **die erste Nachtsicherung mit Kopie läuft am 07.10. 03:30** (die Läufe bis 06.10. meldeten noch „keine Kopie außerhalb“). „Vom Server nicht löschbar“: der Server spiegelt mit `--delete`, Schutz geben die täglichen Schnappschüsse der Box (7). ~~Anlage 1 nennt keine Datenträgerverschlüsselung ✅~~ (falsch, siehe Nachtrag); die Hetzner-Abbilder selbst sind unverschlüsselt	08.10.2026
A15	Wöchentliche Wiederherstellungsprobe läuft	Anlage 1	✅	`scripts/backup-wiederherstellen-probe.sh`, Cron sonntags 04:30; letzter Lauf 04.10.2026, fehlerfrei (Tabelle `Sicherungsstand`). Probe nur mit der Datenbank `lymbe_tenant_demo`	06.10.2026

Nr	Zusage	Fundstelle Vertrag	Stand	Beleg	Datum
A16	Mandantentrennung: eigene DB je Kunde, Suchindex (Qdrant) und Dateiablage (MinIO) mandantengetrennt	Anlage 1	✅	Eigene Postgres-DB je Workspace (`tenant_database_configs`); Qdrant: eigene Sammlung je Workspace und Assistent (`tenant_{id}_bot_{id}`); MinIO: ein Bucket, Ordner je Workspace (`tenants/{id}/`). **Nachtrag 08.10.2026 (A30):** Nachgemessen über `scripts/zugriff.sh` (nur Namen und Zahlen): Qdrant 3 Sammlungen für 2 Workspaces, alle `tenant_{id}_bot_{id}`; Dateiablage nur Ordner mit Workspace- bzw. Postfach-Kennung; Redis-Schlüssel je Assistent/Gespräch, Schlüssel mit IP-Adresse laufen nach höchstens 24 h ab. Code-Prüfung „Mandant B sieht nichts von A“: kein Weg, auf dem ein Workspace Daten eines anderen liest; jeder Zugriff holt den Mandanten aus einer Prüfung auf dem Server. Behoben (Commits fdc627f, bea9c88): API-Wissensquelle konnte mit `minio://` eine fremde Datei einlesen (jetzt Workspace-Prüfung, nur http/https); Glocke im Portal schickte Übergaben mit Name/E-Mail an alle Mitglieder (jetzt nur eigene Assistenten, Inhalte nur mit Recht, nur der offene Workspace); Schnittstellen der Desktop-App gesperrt (410); Glocken-Routen prüfen Zugehörigkeit; Lead/Termin verknüpfen nur mit Sitzung; Upload nur für Assistenten des Workspace; Ablauf-Brücke nur aus dem internen Netz; Test verlangt bei jeder Server-Aktion mit Mandanten-DB eine Zugehörigkeitsprüfung. Live geprüft: fremder Workspace → 403, Brücke von außen → abgelehnt. Bewusst offen: Live-Chat-Kanäle ohne Mandanten-Präfix (eindeutige Zufallskennungen, Umbau nach dem Livegang)	06.10.2026, ergänzt 08.10.2026
A17	Zugangsdaten verbundener Dienste verschlüsselt gespeichert	§ 5 Abs. 4	✅	AES-256-GCM (`lib/encryption.ts`) für Shops, Kalender, WhatsApp, Meta, Mandanten-DB-Passwörter; Verbindungen der Abläufe mit eigenem Schlüssel des Kerns (`AP_ENCRYPTION_KEY`). Hinweis: Signatur-Geheimnisse ausgehender Webhooks liegen im Klartext	06.10.2026
A18	Export im Portal: Gespräche, Kontakte, Dokumente, Gedächtnis als JSON/CSV bzw. Original	§ 8 Abs. 4	❌	Der Export (eine JSON-Datei) enthält Gespräche, Leads, Termine, Übergaben – **Dokumente nur als Metadaten, kein Gedächtnis, keine Abläufe**. Gespräche und Leads gibt es zusätzlich als Excel/CSV/PDF im Posteingang. → Export erweitern oder § 8 Abs. 4 anpassen	
A19	Löschung nach Vertragsende erfasst DB, Qdrant, MinIO, Inngest	§ 8 Abs. 3	✅	`lib/mandant/loeschablauf.ts`: Qdrant, MinIO, Abläufe-Kern, Mandanten-DB samt Rolle, zentrale Zeilen; automatisch 30 Tage nach Vertragsende. Inngest wird nicht je Mandant gelöscht, sondern läuft nach 30 Tagen aus (A5) – innerhalb der Frist aus § 8 Abs. 3	06.10.2026
A20	Workspace-Formular fragt Firma, Anschrift, vertretungsberechtigte Person ab; Checkbox protokolliert Fassung, Zeitpunkt, Name, E-Mail, IP	Vertragsparteien, Abschluss	✅	Seit 06.10.2026 (Commit 466bab8): Rechtsform, Firma, Anschrift, vertretende Person mit Funktion, Telefon; `AvvZustimmung` speichert Fassung, Zeit, Name, E-Mail, IP und die Angaben	06.10.2026

Nr	Zusage	Fundstelle Vertrag	Stand	Beleg	Datum
A20b	Die 4 Testmandanten vom Stand 17.09.2026 sind vollständig gelöscht (Datenbank, Suchindex, Dateiablage, Ereignisspeicher)	Art. 28 Abs. 9, 00 O2	✅ (08.10.2026)	Stand 06.10.: Rest-Datenbank `lymbe_tenant_max_mustermann_ag`. **Nachprüfung 08.10.2026 nach dem Plattform-Reset:** Workspaces nur noch lymbe-vorlagen, tierisch-im-spektrum, demo (neu). Datenbanken: nur deren drei plus Abläufe-Kern ✅. Cache (Redis): kein Schlüssel der alten Mandanten ✅. Suchindex (Qdrant) und Dateiablage (MinIO) hatten noch Reste von 6 bzw. 3 alten Mandanten – von Chris am 08.10. über Admin → Infrastruktur → „Reste“ entfernt, danach nachgemessen: Qdrant 3 Sammlungen nur von demo und tierisch-im-spektrum, MinIO nur der Ordner von tierisch-im-spektrum ✅. Ereignisspeicher (Inngest): Ereignisse aus der Zeit vor dem Reset laufen nach 30 Tagen aus, spätestens 05.11.2026 (A5)	08.10.2026
A21	Hinweis beim Verbinden eines Dienstes zeigt Anbieter und Standort	§ 5 Abs. 1	✅ (08.10.2026)	**Seit 08.10.2026 (Portal 2c1bded, Kern b2e7089b):** Dialog nach 1.5 I vor jeder neuen Verbindung – Anbieter, Sitz, Datenfluss, eigene Verantwortung (Vertrag, Datenschutzerklärung); Zusätze für Postfächer („nur dienstliche“), Drittländer und WhatsApp. **Portal:** Kalender (Google, Outlook, Calendly, Cal.com), Shops (Shopify, Shopware, WooCommerce), WhatsApp, Messenger/Instagram, Benachrichtigungen (Slack, Teams, Webhook), Workspace-Webhooks, API-Datenquellen – Liste `lib/integrations/anbieter.ts`. **Abläufe:** Verbindungsmaske im Baukasten zeigt den Hinweis vor Feldern bzw. OAuth-Knopf (alle Bausteine; bekannte Anbieter mit Sitz, sonst Bausteinname und „Grundlage prüfen“). Live geprüft: Shopify im Portal, Gmail im Baukasten (Abbrechen verbindet nichts). Grundlage „EU-US Data Privacy Framework“ nur bei Google, Microsoft, Meta, Slack; Calendly, Cal.com und unbekannte Anbieter: „Grundlage prüfen“ – Dennis prüft die Angaben gegen (08_Gegenpruefung, A12). Vorher: kein Dialog.	08.10.2026
A22	KI-Kennzeichnung im Widget und Portal-Chat vorhanden; Wechsel Mensch ↔ KI im Live-Chat sichtbar	§ 6 Abs. 2	✅	Widget: Startdialog 1.5 A/P, Kennzeichen „KI“/„Mensch“ im Kopf, Zeilen beim Wechsel (1.5 E), live am 06.10. auf demo geprüft (Commit 92a08c5). Portal-Chat: Hinweis für Mitarbeiter unter dem Eingabefeld	06.10.2026
A23	Kontoinhaber der Verträge: Hetzner = 26lab.io · STACKIT = Flubber Pixels UG · Microsoft Azure = Flubber Pixels UG · OpenAI = Flubber Pixels UG; Flubber bei Hetzner als zweiter Administrator eingetragen, 26lab bei STACKIT, Azure und OpenAI	§ 4 Abs. 1, 2.1 § 17	Teilweise	Kontoinhaber wie genannt (3.1 A). STACKIT beide Owner (05.10.), Hetzner Dennis Zugang (08.10.), Portal-Admin beide (08.10.). Offen: 26lab als zweiter Admin bei OpenAI, Azure, Stripe (D13, D17) – Zugangsliste in 02_Finale_To_Dos Abschnitt 6	11.10.2026

B – Zusagen aus AVV § 12 und zur Websuche (Pflicht vor Freischaltung)

Nr	Zusage	Fundstelle	Stand	Beleg	Datum
B1	**Suchbegriff ohne Personenbezug:** Der Schritt, der aus der Nutzerfrage den Websuche-Begriff bildet, enthält die feste Anweisung, keine Namen, Kontaktdaten oder sonstigen personenbezogenen Angaben zu übernehmen – nur das Thema. Mit 10 Testfragen (Namen, Telefonnummern, Diagnosen) geprüft	AVV § 3 Abs. 10, Anlage 2 Nr. 5	✅	`lib/ai/suchbegriff/anweisung.ts` + Filter/Sperrliste; Testprotokoll 5.16, Lauf 06.10.2026: 30/30	06.10.2026
B2	**Kein Modell-Training:** STACKIT-Vertragsbedingungen belegen, dass Eingaben nicht zum Training genutzt werden	AVV § 3 Abs. 6	✅ (über den Leistungsschein)	Der STACKIT-AVV selbst nennt Training nicht. Vertraglich belegt durch den **Leistungsschein AI Model Serving v1.3** (gültig ab 18.09.2025): „STACKIT does not collect or evaluate any customer data other than billing-relevant data“; Kundendaten „not stored permanently“. Abgelegt in 03_Dienstleister/STACKIT, Fundstellen in 3.1 D. ⚠ AVV Ziff. 2.3 erlaubt die Verarbeitung „anonymisierter Nutzungsdaten für eigene Zwecke“ (keine Inhalte)	08.10.2026
B3	**Kein Modell-Training:** Microsoft-Produktbedingungen für Azure OpenAI (keine Nutzung zum Training; Abuse-Monitoring-Status dokumentieren) und Azure Speech (Logging aus)	AVV § 3 Abs. 6	✅	Kein Training: Microsoft Learn „Data, privacy, and security for Foundry Models sold by Azure“ (Stand 18.05.2026): „prompts and completions are not used to train, retrain, or improve the base models“ (Vorbehalt „without your permission or instruction“ – Stored completions/Fine-Tuning nicht genutzt); die DPA selbst sagt nichts zu Training, S. 9 nur keine Nutzung für Profilbildung/Werbung/Marktforschung. Speicherfrist der Missbrauchsüberwachung nicht mehr veröffentlicht – AVV 1.7 Anlage 2 ohne „30 Tage“ (Gegenprüfung 08a A6–A8). **Missbrauchsüberwachung: aktiv** (kein `ContentLogging=false` an `lymbe-ai`, Azure Resource Graph 08.10.2026; Abschaltung nicht beantragt). **Speech:** schnelle Transkription ohne Speicherung, Audio-Logging aus (Vorgabe, im Code nicht eingeschaltet). Fundstellen in 3.1 D	08.10.2026
B4	Nachrichten-Einordnung (gpt-oss-20b bei STACKIT) erkennt Anliegen, Thema und Stimmung aus Text; keine biometrischen Daten, keine Auswertung von Mitarbeiter-Chats (KI-VO Art. 3 Nr. 39, Art. 5 Abs. 1 lit. f nicht berührt); Stimmung nur als Summe je Assistent	KI-VO Art. 5	✅ (Wortlaut 11.10.2026; Entscheidung 06.10.2026)	Stimmt so nicht: Die Einordnung kennt die Absicht „FRUSTRATION“, die Auswertung zählt Stimmung (positiv/neutral/negativ, Summe je Assistent), die Fähigkeit „Übergabe an das Team“ nennt die Stimmung. Bleibt bewusst (Entscheidung 06.10., Notion A10): nur Text, keine biometrischen Daten, keine Mitarbeiter. Modell ist **gpt-oss-20b** bei STACKIT, nicht 120b. **Neuer Wortlaut:** „Nachrichten-Einordnung (gpt-oss-20b) erkennt Absicht, Thema und Stimmung aus Text; keine biometrischen Daten, keine Auswertung von Mitarbeitern“	06.10.2026

Nr	Zusage	Fundstelle	Stand	Beleg	Datum
B5	Support-Zugriff auf Mandanteninhalte nur nach Freigabe durch die jeweils andere zugriffsberechtigte Person (Vier-Augen-Prinzip), protokolliert im Zugriffsregister 5.15 (Zeit, Person, Grund, Umfang, Mandant) – für alle Mandanten	AVV § 3 Abs. 5	Offen (Dennis)	Technisches Protokoll ✅ (siehe A9). Die Freigabe der zweiten Person ist organisatorisch und wird im Register 5.15 geführt – Dennis bestätigt	
B6	Rollen: Sehen alle Mitglieder eines Workspace alle hochgeladenen Dokumente? (ja/nein – AVV § 12 Abs. 5 geht von „ja" aus)	AVV § 12 Abs. 5	✅ Antwort: im Normalfall ja	Mitglieder mit dem Recht „Wissen ansehen“ (Mitglied, Nur-Ansehen) sehen alle Dokumente der Assistenten, auf die sie Zugriff haben – ohne Zuordnung zu Assistenten sind das alle. Einschränkbar über die Zuordnung zu Assistenten; die Rolle Support sieht keine Dokumente	06.10.2026
B7	Workspace-Formular hat Feld für Telefonnummer des Inhabers (für Vorfallmeldung nach § 12 Abs. 6)	AVV § 12 Abs. 6, Anlage 4	✅	Pflichtfeld Telefon in den Vertragsangaben (Onboarding und Einstellungen → Unternehmen), seit 06.10.2026	06.10.2026
B8	Admin-Einsicht in Frag-Lymbe-Verläufe der Mitarbeiter: Einstellung vorhanden? Standard?	1.6 Textbaustein	✅ Antwort: keine Einsicht	Es gibt keine Einstellung: Verläufe sieht nur die Person selbst (`lib/portal-chat/access-domain.ts`), auch Workspace-Admins und Lymbe-Personal nicht; Inhalte verlassen einen Verlauf nur, wenn die Person ihn teilt oder eine Antwort ins Wissen übernimmt	06.10.2026

C – Zusagen aus der Datenschutzerklärung v1.6

Nr	Zusage	Stand	Beleg	Datum
C1	Demo-Widget auf lymbe.ai: Chats, Leads und Termine nach 24 h gelöscht, kein Gedächtnis, kein Selbstlernen	✅ (08.10.2026)	**Nachtrag 08.10.2026:** Neuer Workspace „demo“ als Demo markiert (Stripe-Testabo dabei beendet, 0,00 €), Assistent „Demo Assistent“ (`cmuz6b4ia0000qp01bzqxia02`): Selbstlernen aus, Kontaktformular aus; Einbindung auf lymbe.ai umgestellt und live geprüft – der Startdialog sagt „spätestens 24 Stunden … gelöscht“, stündlicher Löschlauf. Analytics und Stimmungsauswertung sind an (siehe C2). **Hinweis 08.10.2026 (Christian):** Die Demo läuft für uns selbst auf der Website lymbe.ai (Lymbe AI, Flubber Pixels UG) und ist kein Kunden-Workspace. Leads bleiben bewusst an: Der Assistent fragt im Chat nach Name und E-Mail, damit Interessenten über die Demo Kontakt aufnehmen können (im Live-Test 08.10. gesehen); Leads gehen nur an uns und werden wie die Gespräche nach 24 Stunden gelöscht. Damit gilt „keine Leads“ in dieser Zeile nicht – für Cowork: 1.5 L und Datenschutzerklärung entsprechend fassen (24 Stunden, Kontaktaufnahme über den Chat möglich). Stand 06.10.: Luma (Workspace demo) behielt Gespräche 90 Tage; seit 08.10.2026 (Commit 40421ff) löscht ein als Demo markierter Workspace Gespräche, Leads und Termine nach 24 Stunden. 1.5 L und DSE 1.6 entsprechend gefasst (11.10.2026).	08.10.2026

Nr	Zusage	Stand	Beleg	Datum
C2	Widget überträgt bei jedem Seitenaufruf Referrer und IP; bei eingeschalteter Besuchsanalyse zusätzlich Seitenadresse, Scrolltiefe und Sitzungskennung ohne Personenbezug, nicht bei Do-Not-Track/GPC/Opt-out – so beschrieben in DSE 1.6, 1.3 und 1.5 B	✅ (Text 11.10.2026)	Ohne Chat: Bootstrap-Abruf (Referer-Header), Laden des Chatfensters (iframe) und – **bei eingeschalteter Analyse, Vorgabe an** – Ereignisse mit Seitenadresse, Referrer (erste Seite), Scrolltiefe, Sitzungskennung (`/api/widget/{bot}/events`). Ausgeschaltet bei Do-Not-Track/GPC/Opt-out. Texte entsprechend gefasst (11.10.2026)	11.10.2026
C3	Browserspeicher des Widgets: genau welche Einträge? (`lymbe_ignore`, sessionStorage-Marker, Sitzungs-ID?) – Liste für 5.8	✅ Liste	localStorage: `lymbe_chat_{bot}` (Gesprächskennung, 12 h), `lymbe_consent_{bot}` (Bestätigung, 180 Tage), `lymbe_ignore` (nur auf Wunsch, Analyse-Opt-out). sessionStorage: `lymbe_proactive_seen:{pfad}`, `lymbe_proactive_last`, `lymbe_auto_open_done:{bot}`, `agent_name_{bot}`, `lead_captured_{bot}`, `lead_form_shown_{bot}`, `lymbe_sprache_hinweis`. Keine Cookies (alle Widget-Abrufe ohne Credentials)	06.10.2026
C4	Wächter (GitHub Actions): Meldeweg benennen (welcher Dienst, welche Daten)	✅	`.github/workflows/waechter.yml`, alle 30 Minuten bei GitHub: `app.lymbe.ai/api/puls`, `lymbe.ai`, TLS-Zertifikat. Meldung nur über die eingebaute E-Mail von GitHub an die Person, die die Datei zuletzt geändert hat; keine weiteren Daten. **Nachtrag 08.10.2026 (A18):** Empfänger ist genau, wer die Zeitplan-Zeilen zuletzt geändert hat – heute Christian (chris@26lab.io). Gegen die Abschaltung nach 60 Tagen ohne Commit schaltet der Job „wachhalten“ den Wächter am 1. jedes Monats per GitHub-API wieder ein (statt Leer-Commit, Commit 43637e4); Probelauf #897 am 08.10.2026 erfolgreich	06.10.2026, ergänzt 08.10.2026
C5	Stripe: kein Stripe-Skript im Portal, Checkout nur per Weiterleitung	✅	`@stripe/stripe-js` seit 17.09.2026 entfernt; Checkout per Weiterleitung (`AvailablePlansCard.tsx`); nichts lädt js.stripe.com	06.10.2026
C6	Profilbild bei Google/GitHub-Login wird einmal geholt und lokal gespeichert	✅	`lib/auth.ts` / `lib/profile/anmeldefoto.ts`: beim ersten Login einmal geladen und in der eigenen Ablage gespeichert, nicht verlinkt	06.10.2026
C7	Keine Analyse-/Tracking-Tools, keine fremden Schriften, nur Session-Cookie + CSRF	✅ (präzisiert)	Kein Tracking-Tool, Schrift lokal (Inter, `next/font/local`). Cookies: Sitzung, CSRF, dazu `authjs.callback-url` (Anmeldung) und `onboarding-tenant-id` (1 Stunde, nur beim Anlegen) – **DSE-Satz um diese zwei ergänzen**	06.10.2026

D – Nachweise ablegen (Ordner 03_Dienstleister)

Nr	Nachweis	Datei	Datum
D1	Hetzner AVV (Kundenkonto)	`Hetzner/dpa-2026-10-05.pdf` ✅	05.10.2026
D2	STACKIT AVV / Vertragsbedingungen	`STACKIT/STACKIT_Auftragsverarbeitungsvertrag.pdf`, `STACKIT_TOMs.pdf` ✅	06.10.2026 (geprüft: liegt vor)

Nr	Nachweis	Datei	Datum
D3	Microsoft DPA / Product Terms (Azure)	`Microsoft_Azure/MicrosoftProductandServicesDPA(WW)(German)(May2026)(CR).docx` ✅	06.10.2026 (geprüft: liegt vor)
D4	OpenAI DPA – unterschrieben (openai.com/policies/data-processing-addendum)	`OpenAI/Data_Processing_Agreement_(Flubber_Pixels_UG_.pdf` ✅ (Unterschrift im PDF nicht geprüft)	06.10.2026 (geprüft: liegt vor)
D5	Stripe DPA (Services Agreement)	**fehlt**	
D6	Meta: WhatsApp Business Solution Provider Terms (für später)	fehlt (für später)	

E – Unterschriften

Was	Wer	Datum	Unterschrift
Vertraulichkeitsverpflichtung (5.3)	Christian Gudermann		
Vertraulichkeitsverpflichtung (5.3)	Dennis (Flubber Pixels UG)		
Verpflichtungserklärung § 203 StGB (AVV Anlage 5), belehrt durch Marion Schagen	Christian Gudermann		
Verpflichtungserklärung § 203 StGB (AVV Anlage 5), belehrt durch Marion Schagen	Dennis (Flubber Pixels UG)		
Partnerschaftsvertrag Lymbe (2.1), Fassung 2 vom 11.10.2026 (ersetzt die Unterschrift vom 08.10.2026)	Marion Schagen (Flubber), Christian Gudermann (26lab.io); Dennis als Bevollmächtigter		
Testprotokoll Suchbegriff-Generator (5.16), Lauf 06.10.2026	Christian Gudermann; Gegenzeichnung Dennis		

Abnahme Block A–C: Ich bestätige, dass die oben mit ✅ markierten Zeilen am genannten Datum am laufenden System (lymbe-prod) nachgemessen wurden.

Datum: _____ · Christian Gudermann, 26lab.io: _____

Freigabe AVV v1.7 (inkl. § 12): Datum: _____ · Flubber Pixels UG (Datenschutz-Ansprechpartner Dennis): _____

Folgeregel: Jede Änderung an einer hier bestätigten Einstellung wird vor Umsetzung in Textform an datenschutz@lymbe.ai gemeldet (Partnerschaftsvertrag 2.1 § 12 Abs. 2).